PROJETO INTEGRADOR · POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO

Health In Sight

Portal de divulgação de informações confiáveis sobre saúde

EQUIPE

Guilherme da Silva Bonifácio
Cassiano Jesus da Silva
Yan Baumgarten Costa

ORIENTADOR

Prof. Dr. Fabiano Bezerra Menegidio

INSTITUIÇÃO

Universidade de Mogi das Cruzes
Sistemas de Informação

O conteúdo confiável existe. Ninguém chega nele.

6 em 10

brasileiros buscam informação de saúde na internet

Fonte: IESS

- Informação verdadeira e falsa disputam o mesmo espaço. A OMS chama isso de infodemia.
- O material oficial existe, mas está espalhado por dezenas de portais diferentes.
- E quase sempre em linguagem técnica, escrita para profissional de saúde.

O que o sistema faz, e por quais etapas

OBJETIVO GERAL

Reunir conteúdo de fontes oficiais de saúde num só lugar, com consulta por sintomas e sem diagnóstico, coletando o mínimo de dados de quem usa.

01 · concluído

Autenticação e gestão de credenciais

02 · concluído

Recuperação de senha

03 · concluído

Criptografia e comunicação segura

04 · concluído

Conformidade com a LGPD

05 · concluído

Auditoria e logs

O que já existe, e o que falta em cada um

Portais oficiais

CONFIABILIDADE

Alta

ACESSO

Espalhado em dezenas de sites

DADO SENSÍVEL

Não precisa coletar

Buscadores

CONFIABILIDADE

Varia muito

ACESSO

Imediato

DADO SENSÍVEL

Guarda a pesquisa

Apps de sintomas

CONFIABILIDADE

Média

ACESSO

Bom

DADO SENSÍVEL

Coleta sintomas

Health In Sight

CONFIABILIDADE

Fonte sempre citada

ACESSO

Por sintoma ou por condição

DADO SENSÍVEL

Sintomas não são gravados; guardar material pede consentimento

Os requisitos e a norma de onde cada um saiu

RFC 9106 · IETF, 2021

Senha guardada só como hash Argon2id, com os parâmetros de custo recomendados.

RFC 6238 · IETF, 2011

Login em duas etapas. O segredo fica no celular; no site só se digita o código de seis dígitos.

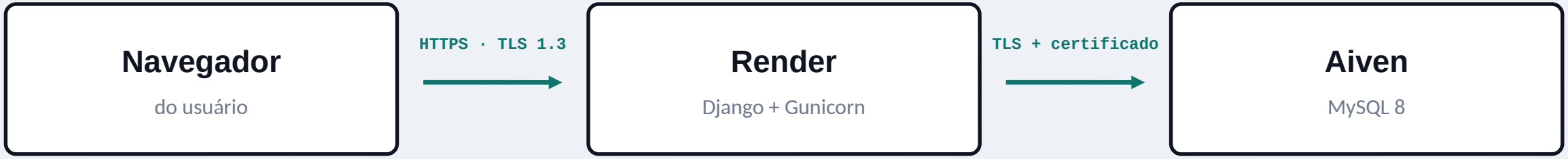
LGPD · Lei 13.709/2018

Coletar o mínimo, pedir consentimento por finalidade e deixar exportar e excluir os dados.

OMS · Infodemic management

Todo conteúdo com fonte oficial citada, para não alimentar a infodemia.

Django em MVT, banco separado da aplicação



MVT

O MVC do Django. A View faz o papel do Controller; o Template faz o papel da View.

Banco relacional no MySQL

15 tabelas com chave primária, chave estrangeira e campos únicos. A estrutura é escrita em Python e aplicada com o migrate.

API externa

API HTTP do Brevo para o e-mail de recuperação de senha. A chave vem de variável de ambiente, e o .env nunca entra no repositório.

TECNOLOGIAS UTILIZADAS

A pilha do projeto

Python 3.12
Linguagem

Django 5.2
Framework web

MySQL 8
Banco relacional

Aiven
Hospedagem do banco

Render
Hospedagem da aplicação

Argon2id
Hash de senhas

django-otp
Segundo fator TOTP

django-axes
Bloqueio por força bruta

AES-256-GCM
Cifragem em repouso

Brevo
Envio de e-mail

WhiteNoise
Arquivos estáticos

Git · GitHub
Versionamento do código

Demonstração

01

Criar conta: o aviso de privacidade aparece e a senha 123456 é recusada.

02

Ativar a verificação em duas etapas lendo o QR Code no celular.

03

Sair e entrar de novo. A senha correta para na tela do código, sem criar sessão.

04

Errar a senha cinco vezes. A sexta tentativa cai na tela de bloqueio.

05

Consultar sintomas: febre e tosse listam condições com fonte; falta de ar manda procurar atendimento.

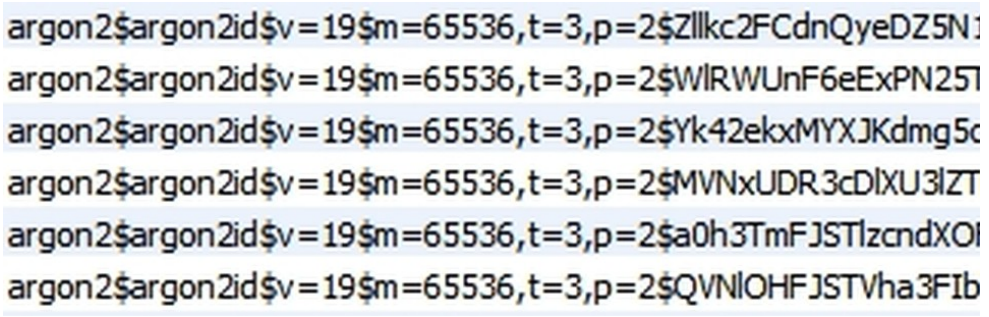
06

Abrir Meus dados: ver o consentimento, exportar em JSON, revogar e excluir a conta.

O que foi testado, e a evidência no banco

Testamos senha, dois fatores, sessão, bloqueio, cadastro, direitos do titular e trilha de auditoria. A cada push, o GitHub Actions roda TruffleHog, Trivy e CodeQL.

Print real do banco: coluna de senhas (e-mails e nomes cortados)



Mesmo formato e mesmos parâmetros em todas, **mas cada hash é diferente**. É o salt único gerado a cada cadastro.

O que ficou pronto, e o que fica para depois

Entregue e publicado

- Senhas em Argon2id e login em duas etapas com TOTP
- Recuperação de senha por link de uso único
- Bloqueio após cinco senhas erradas
- Segredo do 2FA cifrado com AES-256-GCM
- Consulta por sintomas com fonte oficial e sinal de alerta
- Consentimento por finalidade, exportação e exclusão de dados
- Trilha de auditoria encadeada e esteira DevSecOps

Trabalhos futuros

- Ampliar o acervo com mais condições e fontes
- Avisar quem guardou um material quando a fonte muda
- Definir o prazo de retenção da trilha de auditoria
- Guardar os logs também fora do nosso servidor
- Códigos de recuperação para quem perder o celular

Obrigado

BIRYUKOV, A. et al. Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications. RFC 9106. IETF, 2021.

M'RAIHI, D. et al. TOTP: Time-Based One-Time Password Algorithm. RFC 6238. IETF, 2011.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais.

ORGANIZAÇÃO MUNDIAL DA SAÚDE. Infodemic management.

IESS. Seis em cada dez brasileiros dizem buscar informações sobre saúde na internet.

```
https://projeto-politicas-seguranca.onrender.com/
```

```
github.com/Guilheslherme/projeto_politicas_seguranca
```